CISZU NETWORK - DOCUMENTACIÓN OFICIAL Nombre: SECURITY Versión: 3.0.0 Actualización: 2026-08-01 Identificador: SECURITY_V3.0.0_2026_08_01_ciszunetwork

---

SEGURIDAD / SECURITY

[ESPAÑOL]

POLÍTICA DE SEGURIDAD DE CISZU NETWORK

La seguridad de los proyectos, datos y comunidad de Ciszu Network es una prioridad fundamental.

PRINCIPIOS DE SEGURIDAD 1. Privacidad: No compartimos información personal de miembros sin su consentimiento explícito. 2. Transparencia: Las acciones de seguridad son documentadas y comunicadas a la comunidad. 3. Prevención: Implementamos medidas proactivas contra vulnerabilidades y amenazas. 4. Mínimo Privilegio: Cada componente tiene solo los permisos necesarios para funcionar.

MEDIDAS DE SEGURIDAD IMPLEMENTADAS

Código y Dependencias: - Uso de pnpm con ignore-scripts=true para prevenir ejecución de malware en postinstall - TypeScript estricto para reducir errores de tipo y vulnerabilidades - ESLint para análisis estático de código - Prohibido el uso de dangerouslySetInnerHTML (prevención de XSS) - Renderizado nativo de React que escapa y sanitiza automáticamente - Sanitización DOMPurify en componentes compartidos que requieren HTML dinámico - Auditoría de dependencias (pnpm audit, cargo audit, trivy) contra bases CVE/RUSTSEC

MARCO DE DESARROLLO SEGURO (DevSecOps)

Ciszu Network aplica la filosofía DevSecOps: la seguridad se integra en cada etapa del ciclo de vida del desarrollo (SDLC), bajo marcos normativos globales estables: OWASP Top 10, NIST SP 800-218 (SSDF) e ISO/IEC 27001.

- Shift-Left: las pruebas de seguridad se ejecutan lo más temprano posible, desde el pre-commit local hasta el despliegue.
- SAST (Análisis Estático): Semgrep, Secretlint, Gitleaks y CodeQL detectan vulnerabilidades, malas prácticas y secretos directamente en el código fuente.
- DAST (Análisis Dinámico): OWASP ZAP prueba las aplicaciones desplegadas desde el exterior, simulando ataques reales (SQLi, XSS).
- Gestión de secretos: hooks de pre-commit, .env excluido de git y política de rotación de credenciales ante cualquier filtración (Secret Sprawl).
- Reporte de vulnerabilidades públicas: se opera con la base CVE/CWE para el seguimiento de dependencias.

Infraestructura: - Variables de entorno en .env (excluido de git) - Claves públicas (NEXT_PUBLIC_) contienen solo tokens anónimos - Supabase con Row Level Security (RLS) habilitado - Operaciones críticas mediante RPC (Postgres Functions) del lado del servidor - Despliegue automatizado a través de Vercel con HTTPS forzado

Comunidad: - Verificación de cuentas en Discord - Sistema de roles con control de acceso granular - Filtros anti-spam automatizados - Registro de auditoría de acciones de moderación

REPORTAR VULNERABILIDADES Si encuentras una vulnerabilidad de seguridad en cualquiera de los proyectos de Ciszu Network, repórtala inmediatamente a: ciszunetwork@outlook.com (asunto: “Seguridad”).

Por favor, no divulges la vulnerabilidad públicamente hasta que sea resuelta. Trabajamos para responder a todos los reportes de seguridad en un plazo máximo de 48 horas.

CONTACTO DE SEGURIDAD Email: ciszunetwork@outlook.com (Asunto: “Seguridad”)

[ENGLISH]

CISZU NETWORK SECURITY POLICY

The security of Ciszu Network’s projects, data, and community is a fundamental priority.

SECURITY PRINCIPLES 1. Privacy: We do not share member personal information without explicit consent. 2. Transparency: Security actions are documented and communicated to the community. 3. Prevention: We implement proactive measures against vulnerabilities and threats. 4. Least Privilege: Each component has only the permissions necessary to function.

SECURITY MEASURES IMPLEMENTED

Code and Dependencies: - Use of pnpm with ignore-scripts=true to prevent malware execution in postinstall - Strict TypeScript to reduce type errors and vulnerabilities - ESLint for static code analysis - Prohibited use of dangerouslySetInnerHTML (XSS prevention) - Native React rendering that automatically escapes and sanitizes - DOMPurify sanitization in shared components requiring dynamic HTML - Dependency auditing (pnpm audit, cargo audit, trivy) against CVE/RUSTSEC databases

SECURE DEVELOPMENT FRAMEWORK (DevSecOps)

Ciszu Network applies the DevSecOps philosophy: security is integrated into every stage of the software development lifecycle (SDLC), under stable global regulatory frameworks: OWASP Top 10, NIST SP 800-218 (SSDF) and ISO/IEC 27001.

- Shift-Left: security tests run as early as possible, from local pre-commit to deployment.
- SAST (Static Analysis): Semgrep, Secretlint, Gitleaks and CodeQL detect vulnerabilities, bad practices and secrets directly in source code.

- DAST (Dynamic Analysis): OWASP ZAP tests deployed applications from the outside, simulating real attacks (SQLi, XSS).
- Secrets management: pre-commit hooks, .env excluded from git, and credential rotation policy after any leak (Secret Sprawl).
- Public vulnerability reporting: operations rely on the CVE/CWE base for dependency tracking.

Infrastructure: - Environment variables in .env (excluded from git) - Public keys (NEXT_PUBLIC_) contain only anonymous tokens - Supabase with Row Level Security (RLS) enabled - Critical operations via RPC (Postgres Functions) server-side - Automated deployment through Vercel with forced HTTPS

Community: - Discord account verification - Role system with granular access control - Automated anti-spam filters - Moderation action audit logging

REPORTING VULNERABILITIES If you find a security vulnerability in any of the Ciszu Network projects, report it immediately to: ciszunetwork@outlook.com (subject: “Security”).

Please do not disclose the vulnerability publicly until it is resolved. We work to respond to all security reports within a maximum of 48 hours.

SECURITY CONTACT Email: ciszunetwork@outlook.com (Subject: “Security”)